

Key Management System (KMS)

1. Log in to your AWS account and use AWS Key Management Service (KMS) to create a new symmetric customer managed key named 'FoodieAppKey' for encrypting Zomato-style order data. Note down the key ARN and set an alias for easy identification.

ANS

1. Log in to the **AWS Management Console**.
 2. Search for **AWS Key Management Service (KMS)**.
 3. Click **Customer Managed Keys**.
 4. Click **Create Key**.
 5. Select:
 - **Key Type:** Symmetric
 - **Key Usage:** Encrypt and Decrypt
 6. Click **Next**.
 7. Enter the following details:
 - **Key Name:** FoodieAppKey
 - **Alias:** alias/FoodieAppKey
 8. Assign administrators and key users (if required).
 9. Review the configuration and click **Finish**.
2. In AWS KMS, enable automatic key rotation for the 'FoodieAppKey' you created. Take a screenshot of the rotation status showing it is enabled.

ANS

- 1) Open AWS KMS.
- 2) Select FoodieAppKey.
- 3) Open the Key Rotation section.
- 4) Click Edit.
- 5) Enable Automatic Key Rotation.
- 6) Save the changes.

❖ Result

- The key rotation status changes to:
- Automatic Key Rotation: Enabled

3. Write a short note comparing how key rotation is handled in AWS KMS versus Azure Key Vault. Mention at least two similarities and two differences.

ANS

Feature	AWS KMS	Azure Key Vault
Automatic Key Rotation	Supports automatic rotation for symmetric customer-managed keys.	Supports automatic key rotation through Key Rotation Policies.
Cloud Integration	Integrated with AWS services such as S3, EBS, RDS, Lambda, and DynamoDB.	Integrated with Azure Storage, Azure SQL Database, Virtual Machines, and other Azure services.

❖ **Similarities**

1. Both securely store and manage encryption keys.
2. Both support automatic key rotation and detailed audit logging.

❖ **Differences**

1. AWS KMS is designed for AWS services, while Azure Key Vault is designed for Azure services.
 2. AWS KMS manages key rotation through KMS settings, whereas Azure Key Vault uses configurable Key Rotation Policies with expiration and notification options.
4. Use AWS KMS to generate a data encryption key (DEK) with the 'FoodieAppKey', then encrypt a sample order string (e.g., 'OrderID: 12345, Item: Pizza') using the DEK. Show both the encrypted and decrypted outputs.

ANS

- 1) Generate the DEK
- 2) Encrypt Sample Data
 - Sample Order:
 - OrderID: 12345, Item: Pizza
- 3) Example Encrypted Output:
 - QkFTRTY0RW5jcnlwdGVkRGF0YQ==
- 4) Decrypt the Data
 - aws kms decrypt \
- 5) Example Decrypted Output
 - OrderID: 12345, Item: Pizza

❖ Explanation

- Plaintext is the temporary AES-256 data encryption key.
- CiphertextBlob is the encrypted version of the data key, protected by the KMS customer-managed key.

5. Use ChatGPT to draft a sample key rotation policy for a Flipkart-style e-commerce app, specifying rotation frequency, notification process, and steps to handle compromised keys. Paste the generated policy and highlight any changes you would make for your own app.

ANS

- 1) **Policy Name:** Key Rotation Policy
- 2) **Purpose:** Protect customer payment information, order details, and personal data by regularly rotating encryption keys.

❖ Policy

1. Customer-managed encryption keys must be rotated automatically every **365 days**.
 2. Critical payment-processing keys must be reviewed every **90 days**.
 3. Security administrators must receive email notifications before scheduled key rotation.
 4. All applications must be tested after key rotation to ensure encryption and decryption continue to function correctly.
 5. If a key is suspected to be compromised:
 - Disable the affected key immediately.
 - Create a new customer-managed key.
 - Re-encrypt sensitive data using the new key.
 - Review AWS CloudTrail logs to identify unauthorized activity.
 - Notify the security team and document the incident.
- 3) For my own application, I would:
- Rotate high-risk keys every **180 days** instead of once a year.
 - Enable Amazon CloudWatch alerts for unusual KMS activity.
 - Restrict key administration to a dedicated security team using least-privilege IAM roles.
 - Enable Multi-Factor Authentication (MFA) for all users who can manage or administer KMS keys